Scope

This standard applies to every third-party vendor that will process, store or transmit Acme data. It does not apply to one-off purchases of shrink-wrapped software with no data access.

Starting a review

A review is started by filing Form VSR-204 with the vendor risk team. The form must name a business sponsor and the data the vendor will touch. Reviews are started at least thirty business days before the intended contract signature.

Data classification tiers

Every vendor engagement is assigned a tier. The tier drives both the evidence required and how long records are kept.

Tier	Data the vendor sees	Retention
Tier 1 Public	published material	2 years
Tier 2 Internal	internal documents	5 years
Tier 3 Restricted	customer or staff data	10 years

Tier 3 Restricted data must not leave the Acme network without an approved encryption gateway.

Review procedure

1. The business sponsor files Form VSR-204 and names the data involved.
2. The vendor risk team assigns a tier within two business days.
3. The vendor receives the security questionnaire for the assigned tier.
4. The security team reviews the returned questionnaire within five business days of receipt.
5. Where the questionnaire shows a gap, the vendor submits a written remediation plan with owners and dates before the review continues.
6. The security team verifies any remediation the plan calls complete.
7. For Tier 3 Restricted engagements the vendor also supplies a penetration test report no more than twelve months old.
8. The vendor risk team records a decision of approved, approved with conditions, or declined.
9. Conditions are tracked by the business sponsor until they are closed.
10. The decision and its evidence are filed against the contract.

Reassessment

An approved vendor is reassessed annually. A reassessment is also triggered before that date by a material change: a new data tier, a sub-processor the vendor had not declared, or a reported breach affecting the vendor.

Exclusions

This standard does not cover vendor commercial terms, pricing or payment schedules, which are owned by procurement.